

- [SECURISER UNE APPLICATION WEB](#)
 - [Section1 - LES TEST DE VULNERABILITES](#)
 - [BLACK BOX TEST](#)
 - [WHITE BOX TEST](#)

SECURISER UNE APPLICATION WEB

Comment sécuriser mon application web contre les attaquants et les pirates informatiques ?

Section1 - LES TEST DE VULNERABILITES

BLACK BOX TEST

- **Black Box** : Le test Black-Box est une méthode de test de logiciel qui examine la fonctionnalité d'une application sans avoir son code source ou des informations sur ses structures internes ou son fonctionnement.

Cela simule l'approche d'un attaquant externe qui n'a pas accès à des informations détaillées sur les systèmes cibles. Voici un exemple de "Black Box" en sécurité web :

Test de pénétration externe

Dans le cadre de ce test, les pentesteurs (testeurs de pénétration) agissent comme des attaquants potentiels pour identifier et exploiter les vulnérabilités dans les applications web, les serveurs, les dispositifs réseau, et d'autres composants accessibles via internet. L'objectif est de découvrir des faiblesses exploitables sans aucune connaissance interne du système, telles que :

- **Injection SQL** : Les testeurs essaient d'injecter du code SQL malveillant dans les champs d'entrée pour voir si l'application web exécute ces commandes, ce qui pourrait permettre l'accès à la base de données sans autorisation.
- **Cross-Site Scripting (XSS)** : Ils recherchent des failles permettant d'injecter des scripts malveillants dans les pages vues par d'autres utilisateurs, pouvant conduire au vol de cookies ou à d'autres attaques.
- **Fuzzing** : Cette technique consiste à envoyer des données aléatoires ou inattendues à l'application web pour voir comment elle réagit, cherchant des

points de défaillance qui pourraient être exploités.

- **Analyse des configurations** : Vérification des configurations de sécurité du serveur et des applications pour identifier les réglages par défaut non sécurisés ou les mauvaises configurations.
- **Découverte de contenu caché** : Utilisation d'outils pour automatiser la recherche de fichiers, répertoires ou fonctionnalités cachées non sécurisées sur le site web.

Ces tests sont effectués avec l'autorisation des propriétaires du système et dans le cadre d'un accord clair définissant le périmètre, les méthodes et les objectifs du test pour éviter les dommages accidentels au système ou aux données.

WHITE BOX TEST

- **White Box** : Le test White Box est une méthode de test d'un logiciel qui teste les structures interne ou le fonctionnement d'une application, en ayant toutes les informations possibles, contrairement aux test Black Box. Une perspective interne du système, ainsi que des compétences en programmation, sont utilisées pour concevoir des scénarios de test.

Cette méthode permet une analyse en profondeur du code source, de la structure de la base de données, des flux de données, et des chemins d'exécution. Voici quelques exemples et techniques couramment utilisées dans cette approche :

- **Analyse statique du code** : Également connue sous le nom d'analyse de code source, cette technique consiste à examiner le code source d'une application pour identifier les failles de sécurité potentielles sans exécuter le programme. Les outils d'analyse statique peuvent détecter des vulnérabilités telles que les injections SQL, les failles de cross-site scripting (XSS), et les erreurs de configuration.
- **Analyse dynamique du code** : Contrairement à l'analyse statique, l'analyse dynamique s'effectue pendant l'exécution de l'application. Elle permet d'identifier les comportements anormaux et les vulnérabilités qui ne sont visibles qu'à l'exécution.
- **Revue de code** : La revue de code par des pairs est une pratique où d'autres développeurs examinent le code source pour identifier les erreurs et les vulnérabilités potentielles. C'est une étape cruciale pour assurer la qualité et la sécurité du code avant sa mise en production.
- **Test d'intrusion interne** : À l'opposé des tests d'intrusion en approche Black Box, les tests d'intrusion internes utilisent des connaissances internes pour

simuler des attaques sur le système. Cela peut inclure l'exploitation de vulnérabilités connues, le test des contrôles d'accès et la simulation d'attaques par des utilisateurs malveillants internes.

- **Modélisation de la menace** : Cette technique implique l'identification des actifs précieux, des vecteurs de menace potentiels, et des vulnérabilités qui pourraient être exploitées par un attaquant. Elle aide à comprendre le paysage de menace d'une application et à prioriser les efforts de mitigation.
- **Vérification des dépendances et des composants tiers** : Les applications modernes utilisent souvent des bibliothèques et des frameworks tiers. L'inspection de ces composants pour des vulnérabilités connues est essentielle car ils peuvent introduire des failles de sécurité dans l'application.

Exemple concret : Imaginons une application web de commerce électronique. En appliquant l'approche White Box, l'équipe de sécurité pourrait commencer par une analyse statique du code pour identifier toute utilisation inappropriée des requêtes SQL qui pourrait mener à une injection SQL. Ensuite, une analyse dynamique pourrait être utilisée pour tester la gestion des sessions et la mise en œuvre de l'authentification, s'assurant qu'il n'y a pas de fuites d'informations ou de possibilités de détournement de session. Parallèlement, une revue de code pourrait se concentrer sur la manière dont les données des utilisateurs sont validées et nettoyées avant d'être traitées pour éviter les attaques XSS.

L'approche White Box, avec sa perspective interne détaillée, est complémentaire à l'approche Black Box pour fournir une sécurité web robuste en couvrant à la fois les perspectives internes et externes.

Note : Il y a aussi le Grey Box qui se situe entre le Black Box Ttesting et le White Box testing, combinant des éléments des deux méthodes pour offrir une perspective unique sur l'analyse de la sécurité. Dans cette approche, le testeur a un accès limité ou partiel au code source et à la structure interne de l'application, contrairement au White Box où l'accès est total, et au Black Box où le testeur n'a aucun accès au code ou à la structure interne. Cette méthode permet d'imiter un attaquant avec certaines connaissances internes du système, telles que des informations sur les configurations, les schémas de base de données ou les API, sans pour autant avoir une vision complète de l'application